第三章

信息安全的基本目标：**保密性、完整性、可用性**，可控性

信息安全的发展历程：物理安全、网络安全、应用安全、数据安全

信息安全的主要威胁（人为失误，信息截取，内部窃密破坏，黑客攻击，技术缺陷，病毒）

安全威胁的主要表现特征：窃听，重传，伪造，篡改，拒绝服务攻击，行为否认。。。

攻击者攻击的主要对象：网络基础设施，公共互联网，新兴技术（比如云计算）

社会工程学攻击是攻击者通过利用人的心理弱点和行为习惯，诱骗合法用户泄露敏感信息或执行非法操作的一种攻击方式。

攻击形式包括：钓鱼，下饵，冒充（假托）等等

PDRR 模型是一种**信息安全管理与防护的整体框架模型**

PDRR 分别代表：

- **P — Protection（防护）**
- **D — Detection（检测）**
- **R — Response（响应）**
- **R — Recovery（恢复）**

第4章密码学

MD5 主要特点：输出长度：128 位 ， 输入长度：任意 ， 已被证明存在碰撞漏洞

SHA-1输出长度：160 位 ， 安全性高于 MD5 ， 已被发现存在碰撞攻击

基于 DES 的 MAC 与基于 Hash 的 MAC消息认证码 对比表

对比项	基于 DES 的 MAC	基于 Hash 的 MAC
使用算法	对称加密（DES）	Hash 函数
计算效率	较低	较高
安全依赖	DES 安全性	Hash 抗碰撞性

数字签名是一种利用公钥密码体制和 HASH 函数，对电子数据进行签名和验证的技术，用于保证数据完整性、发送方身份认证和不可否认性。

比如基于RSA,DSA的签名体制。

操作系统安全

模型	核心安全目标	安全控制规则	典型应用
Bell–LaPadula	机密性	低级不读上、高级不写下 允许读操作当且仅当 Ls ≥ Lo 允许写操作当且仅当 Lo ≥ Ls	军事安全策略
Biba	完整性	不读下、不写上 一个主体只能向完整性级别不低于其自身完整性级别的客体写入 一个主体只能读取完整性级别不高于其自身完整性级别的客体	商业安全策略

TCSEC（Trusted Computer System Evaluation Criteria）

- 又称 **橙皮书（Orange Book）**
- 是美国国防部制定的 **计算机系统安全评价标准**
- 对系统安全功能和可信度进行分级

2️⃣ 安全等级分类（D ~ A 类）

D 类：未评价系统

C 类：自主保护系统（Discretionary Protection）

B 类：强制保护系统（Mandatory Protection）

A 类：验证保护系统（Verified Protection）

第7章网络安全

中间人攻击是指攻击者在通信双方之间秘密截获、篡改或伪造信息，使通信双方误以为直接通信，从而获取敏感信息或操控通信内容。

防火墙类型	原理	典型应用
包过滤防火墙	基于连接规则	边界路由器防护
状态检测防火墙	基于包的首部或数据段	企业边界网络、防护关键服务
应用层防火墙	基于代理行为过滤	HTTP、FTP、邮件代理服务

IDS 入侵检测系统 是监控网络或系统活动，发现未授权访问、攻击或异常行为的安全系统

分为基于标记，启发式，秘密模式

第8章

攻击面（输入点）	资源名/URL；GET/POST 参数；Referer、User-Agent；HTTP 方法；Cookie；以及 Ajax/Web Service/Flash 客户端/Java Applet 等更多输入点
典型 Web 攻击	跨站脚本攻击XSS；各类注入（SQL/Command/SSI/XPath…）；DDoS；恶意软件（Trojan/Worm/Spyware…）
常见安全事件/后果	网页篡改、网页挂马、敏感信息泄露、拒绝服务、钓鱼攻击等
分层防护体系（安全视图）	Firewall：网络端口访问控制、UDP/TCP 状态感知； IDS/IPS：基于规则的异常检测、入侵防护、已知漏洞管理； WAF：HTTP/S 应用保护、会话管理（Cookie 安全）、内容控制、数据泄露管理

漏洞	关键要点（能写成简答）	课件中的典型提示/例子
SQL 注入	输入参与拼接数据库查询/OS 命令；可能经由数据库调用 OS 命令链路扩展危害	登录绕过示例：`pwd='123' or '1=1'` 使查询恒真通过验证
XSS（跨站脚本）	可窃取会话/模拟用户操作；常分存储型与反射型	存储型流程：服务器存储恶意代码→用户浏览→返回并执行；存储型案例：`<script>alert('hello')</script>`；反射型：恶意代码藏在链接中并被“reflected”返回执行
CSRF	常借助 XSS；也可能不依赖 XSS，而利用 HTML 标签特性（如邮件隐藏链接）	“不明邮件中隐藏的 html 链接”

第9章

安全软件开发生命周期（SSDL）

重点项	必背要点
定义与目标	SSDL是在软件开发各步骤中嵌入安全活动，目标是确保安全的软件成功实现。
五个主要部分	**(1)安全原则/规则/规章（保护性需求）→ (2)安全需求工程 → (3)架构与设计评审 + 威胁建模 → (4)安全编码 → (5)安全测试。**

PE 文件型病毒

重点项	必背要点
文件感染的核心要求	让目标PE具备病毒功能，但不破坏宿主原功能与外在形态（例如图标）。
感染为什么容易“翻车/暴露”	病毒插入宿主不同位置会迫使修改PE头相关参数；改错会导致宿主异常从而暴露。
Win32 运行/夺权总流程（顺序要会写）	用户触发HOST→装载到内存→通过**AddressOfEntryPoint + ImageBase**定位第一条指令→执行（病毒可能在入口或运行中夺权）→病毒执行后归还控制权→HOST继续运行。
AddressOfEntryPoint（AEP）	PE装载器准备运行的第一条指令RVA；属于病毒感染的关键字段。
ImageBase	PE优先装载地址；入口定位常用AEP+ImageBase；但发生重定位时ImageBase不一定等于真实装载位置。
常见感染方式（控制权交换）	通过改入口点AEP或EPO等方式夺权；需记录原控制点，病毒执行后归还；通常还会设置感染标记避免重复感染。
感染对象与遍历搜索	常感染PE格式文件（EXE/SCR/DLL等）；全盘/部分盘符遍历常用FindFirstFile、FindNextFile。
病毒为何需要重定位	寄生位置不固定；DLL加载位置/注入环境不确定，因此需要重定位；课件给出利用 Call 语句进行重定位思路。
为何“自获取API函数”（不走宿主导入表）	直接改host导入节会引起结构变化、修正成本高，甚至破坏原功能；因此病毒倾向自行解析API。
自获取API的关键API与套路	关键API：GetProcAddress、LoadLibraryA；套路：先找kernel32.dll 模块基址，再通过导出表定位函数地址。

重点项	必背要点
捆绑释放型病毒（典型：熊猫烧香）	病毒体内“携带HOST数据”：运行时先执行病毒，再还原执行HOST；优点实现简单效率高、可感染自校验程序；缺点主体是病毒更易被发现且图标等异常。
系统感染型病毒（扩展常考点）	不感染PE文件、目标是操作系统；两关键问题：再次获得控制权（自启动）与传播；自启动手段包括注册表键值、特定位置/文件、Autorun.inf、嵌入触发代码、DLL劫持等。

	病毒	蠕虫
存在形式	寄生	独立个体
复制机制	插入到宿主程序中	自身复制
传染机制	宿主程序运行	系统存在漏洞
搜索	针对本地文件	针对网络上的计算机
触发传染	计算机使用者	程序自身
影响重点	文件系统	网络，系统性能
防治	从宿主程序中摘除	为系统补丁

重点项	必背要点
木马本质	木马本质是远程控制程序。
木马 vs 合法远程控制软件	木马通常不通知用户、不经允许；合法远控对敏感操作会提示并请求授权。
木马结构	典型为“被控端/服务端木马程序 + 控制端程序（客户端）+ 配置程序（生成/配置参数）”。
木马典型功能	例如：窃取密码、文件操作、修改注册表、系统操作等。
木马常见获取安装机会	常通过诱骗用户安装实现入侵（与“组合攻击”路径关联）。